

Potential Path Traversal

Assessment Identifier: **WS-STA-03** | Assessment Type: **Static** | Date: **September 08, 2026**

Severity: HIGH	CVSS: 7.5	CWE: CWE-22
OWASP: A01 / A03	WASC ID: N/A	Confidence: High candidate
Target / Component: src/components/DeckGLMap.ts / related code	Affected URL: https://github.com/worldmonitor/worldmonitor/blob/main/src/components/DeckGLMap.ts	Parameter: Map layer resource path input

1. Description

Static analysis identified a potential path-traversal data flow. The risk exists if attacker-controlled input can influence a filesystem path and cause access outside an intended directory.

2. Steps to Reproduce

- Run the application locally.
- Identify the input influencing the filesystem path.
- Determine whether it is user-controlled.
- Use a harmless traversal value such as ../test.txt.
- Verify whether path resolution remains within the intended directory.

3. Controlled Proof of Concept

Safe Proof of Concept:
Create a local test directory containing an allowed file and a separate harmless test file outside it. Attempt to reference the outside test file using ../ and confirm that secure behavior denies access.

4. Business & Security Impact

If confirmed, path traversal could permit unauthorized access to files outside the application's intended directory.

5. Remediation Recommendations

Primary Fix: Validate paths, use an allowlist, canonicalize paths, and verify the final resolved path remains inside the approved base directory.

- Validate and canonicalize all file paths using path.resolve() or path.normalize().
- Maintain an explicit allowlist of permitted map assets and configuration directories.
- Reject any input containing traversal sequences such as '..' or null bytes.

6. Evidence & Validation

Evidence Type: Textual / Static Source Analysis
This finding was identified through static analysis of repository source code and configuration files. Per assessment requirements, no simulated runtime screenshots or dynamic PoC captures are applicable. Verification must be performed via source code review and static analysis tool verification.

Authorization & Safety Compliance: *This security assessment was conducted strictly under authorized parameters in accordance with ethical hacking standards. All validations and safe proof-of-concept tests were non-destructive. No persistent modifications or sensitive data exfiltration occurred.*